

@swapsays_wtf

Compliance to follow before launching your App.

Launching a subscription app without knowing these rules is like driving without a licence — you might be fine for a while, but when it goes wrong, the fines are brutal. This guide covers every rule that matters for indie app builders, ranked by risk level.

Risk Overview

Rule	Max Fine / Consequence
Auto-Renewal Disclosure	Up to \$51,744 per user (FTC)
Simple Cancellation	Up to \$51,744 per user (FTC Click-to-Cancel)
Privacy Policy / Data	Up to 4% global revenue or €20M (GDPR)
Consent Before Tracking	App rejection + GDPR fine
Free Trial Reminders	Account frozen, \$60M+ settlements on record
Apple & Google Billing	App removed, payments withheld
Disputes & Chargebacks	Account frozen for up to 180 days
International Billing	VAT penalties + removal from stores
COPPA (Minors)	Up to \$51,744 per child per violation
Accessibility	Discrimination lawsuits (ADA / EN 301 549)

1. Auto-Renewal Disclosure

Highest fine risk — \$51K per user. Must be visible on paywall, not in ToS.

What the law says

- FTC Negative Option Rule (US): Disclosures must be clear, conspicuous, and made immediately before purchase. Pre-checked boxes do not count as consent.
- California ARL: Must clearly show recurring charge amount, billing frequency, trial length, and how to cancel — all on the same screen as the purchase button.

- EU / GDPR: Users must actively and explicitly consent to each recurring charge. Bundling into a generic 'I agree' checkbox is not compliant.

What 'clearly and conspicuous' actually means

Requirement	Standard
Location	Same visual field as the purchase button
Font size	Not smaller than surrounding body text
Visibility	Cannot be hidden behind a scroll, tooltip, or 'learn more' link
Contrast	Grey text on white background does NOT qualify
Placement	Above the buy button — not below it

What to actually do

- Display on your paywall: exact amount charged, billing frequency (weekly/monthly/yearly), and when the first charge hits.
- Use plain language: 'You'll be charged \$9.99/month, starting after your 7-day free trial. Cancel anytime.' That is all it takes.
- No dark patterns: no pre-checked boxes, no confusing toggle states, no hiding the price in small text.
- FTC's Click-to-Cancel Rule (effective April 2025) carries civil penalties of up to \$51,744 per violation.

IF YOU SKIP THIS

- FTC civil penalties: up to \$51,744 per violation — per user.
- Apple and Google will reject your app during review if paywall does not meet subscription disclosure guidelines.
- Each individual user who did not receive a proper disclosure is a separate violation — this adds up fast.

2. Simple Cancellation

Federal law since April 2025. Hiding the cancel button is now explicitly illegal.

What the law says

- FTC Click-to-Cancel Rule: If a user signed up online, they must be able to cancel online just as easily. One-click cancellation from within the app or web dashboard is the standard.
- No forced retention flows: You can offer a discount or ask why they're leaving — but you cannot require them to complete a retention flow before they can cancel.
- Same medium rule: If users signed up through the app, they must be able to cancel through the app. You cannot force them to call a phone number or email support.
- New York (Nov 2025): Requires cancellation through the same medium used to sign up, plus any other medium where a user can consent to the subscription.

What to actually do

- Put a 'Manage Subscription' or 'Cancel Subscription' button in your app's settings or account screen — not buried three menus deep.
- For iOS apps: Link directly to the iOS subscription management page (Settings > Apple ID > Subscriptions) and also provide a direct link in your app settings.
- For Android apps: Link directly to the Google Play subscription management page via the Play Store deep link.
- On your website: Add a cancellation option to your account dashboard. If you sell through your website, this is legally required.
- Test the flow yourself: Time how long it takes to cancel. If it takes more than 2 taps from the settings screen, simplify it.

IF YOU SKIP THIS

- FTC civil penalties under the Negative Option Rule: up to \$51,744 per violation — per user.
- Apple and Google will reject or remove apps that hide cancellation or use manipulative UI to prevent it.
- Class-action lawsuits for 'roach motel' subscription flows (easy in, hard out) are increasingly common in the US.

3. Privacy Policy & Data Disclosure

Pre-condition for everything else. Without it, your app gets rejected before billing even matters.

If your app collects any user data — even just an email address — you are legally required to have a privacy policy. This applies globally and is enforced by app stores as well as regulators.

What the law says

- GDPR (EU): Must disclose what data is collected, how it is used, and which third-parties have access. Fines up to 4% of global annual revenue or €20M — whichever is higher.
- CCPA (California): Users must be able to opt out of data sale. Failure to disclose = \$2,500–\$7,500 per intentional violation.
- India DPDP Act (2025): Requires user consent for data processing, data localisation for sensitive categories, and a designated Data Protection Officer for larger apps.
- HIPAA (Healthcare apps): Any app that handles health data needs a separate compliance layer, a signed BAA with any processors, and breach notification procedures.
- App Store rules: Both Apple and Google require a privacy policy linked in your App Store listing before approval.

What to actually do

- Write a plain-English privacy policy — tools like Termly or Iubenda generate compliant drafts in minutes.
- Link it in your App Store listing, your app's settings screen, and your website footer.
- If you use third-party SDKs (analytics, crash reporting, ads), list them in your privacy policy and disclose what data they collect.
- If your app is in healthcare: get a lawyer. HIPAA penalties go up to \$1.9M per violation category per year.

IF YOU SKIP THIS

- GDPR fines: up to 4% of global annual revenue or €20M — whichever is higher.
- App Store and Play Store will reject your app without a linked privacy policy.
- India's DPDP Act (2025) is now enforceable — relevant if you have Indian users.

4. Consent Before Tracking

Required before any analytics SDK fires. Getting this wrong is the #1 GDPR violation for apps.

What the law says

- GDPR: You must obtain prior consent before activating SDKs and cookies to collect device data or in-app behaviour for analytics and marketing.
- Apple ATT (App Tracking Transparency): Mandatory iOS prompt required before tracking users across apps or websites. Skipping it = App Store rejection.

- Bundling tracking consent into a generic 'I agree to Terms' checkbox is not compliant under GDPR or ATT guidelines.

What to actually do

- Show Apple's ATT prompt before initialising any cross-app tracking SDK (Facebook Pixel, AppsFlyer, etc.).
- For EU users: implement a proper consent management platform (CMP) — Iubenda, Cookiebot, or OneTrust all have mobile SDKs.
- Do not initialise PostHog, Firebase Analytics, Meta Pixel, or similar tools until the user has consented — not before.
- Log consent events with timestamps in case you are ever audited.

IF YOU SKIP THIS

- Activating analytics before consent = GDPR violation, even if you never look at the data.
- Apple will reject apps that don't show the ATT prompt before cross-app tracking.
- Regulators have issued fines for cookie/tracking consent violations in the millions of euros.

5. Free Trial Reminder Emails

Legally required notification before charging. Skipping this is the #1 cause of chargebacks.

What the law says

- Trial under 31 days: Send a reminder email at least 3 days before the trial ends. Must clearly state the charge amount, the date it will be applied, and how to cancel.
- Trial over 31 days: Notify users between 3 and 21 days before the cancellation deadline, per California's Automatic Renewal Law (effective July 2025).
- Annual subscriptions: Send a renewal reminder before each annual renewal — required under California, Minnesota, and New York auto-renewal laws (2025).
- FTC Negative Option Rule (US): Applies to all subscription models, not just trials. Any charge that a user did not explicitly re-authorise needs a reminder.

What to actually do

- Set up automated email reminders (Resend, Mailchimp, etc.) triggered 3 days before trial end.
- Include in every reminder: exact charge amount, billing date, cancellation link, and your support email.

- Log every reminder sent — date, recipient, content — in case you ever need to defend against a dispute.
- Show a reminder inside the app too. An in-app banner or push notification the day before is best practice.

⚠️ IF YOU SKIP THIS

- Stripe dispute threshold: above 0.75% your account goes under review; above 1% can trigger account termination.
- Instacart paid \$60M in consumer refunds in December 2025 for failing to disclose free trial to paid conversion clearly.
- Uber faced an FTC lawsuit joined by 21 states in December 2025 for charging users without consent.

6. Apple & Google Billing Rules

You must use in-app purchase for digital goods. Bypassing it gets your app removed and money withheld.

Current rules (as of 2025–2026)

- US market (post-Epic ruling): Both Apple and Google are required by court order to allow external payment links in apps. You can legally direct users to a web checkout in the US — but IAP must still be offered as an option.
- Outside the US: Rules still largely require in-app purchases for digital goods. The EU's Digital Markets Act gives some flexibility, but the global default is still IAP.
- What you cannot do anywhere: Silently bypass IAP by embedding a third-party payment form (e.g. Stripe form) directly inside your app UI. This is against store policy globally.

Commission rates (2026)

Scenario	Commission Rate
Standard (most apps)	30%
Small Business Program (under \$1M/year)	15% — apply separately on Apple and Google
Subscriptions after year 1	15% on both platforms
External web payments (US only)	~3-4% processing only — but you handle tax compliance yourself

What to actually do

- For most indie apps: Use Apple IAP and Google Play Billing. It handles tax, compliance, refunds, and receipts automatically.
- To reduce the cut (US apps): Add an external payment link directing users to your website. You still must offer IAP as an option.
- Never embed a third-party checkout inside the app: No Stripe form inside your app UI. This violates store policy in most regions.
- Use RevenueCat to manage subscriptions across both platforms — handles receipts, entitlements, and webhook events.
- Apply for Apple Small Business Program if revenue is under \$1M/year — saves 15%.

⚠ IF YOU SKIP THIS

- Apps that bypass IAP without following the correct external link process face removal from the store — not just a warning.
- Apple can withhold your pending payments if your app is removed for policy violations.
- Google removed several Indian apps in 2024 for non-compliance with its billing policy, affecting their entire user base overnight.

7. Managing Disputes & Chargebacks

High dispute rate doesn't just cost money — it can freeze your entire payment account.

Thresholds to know

Processor	Threshold & Consequence
Stripe	Above 0.75% — account review; above 1% — account termination + rolling reserve
PayPal	Above ~1% — funds held for 21+ days; documented cases of \$40K+ frozen for 180 days
Visa VAMP (2025)	New program launched April 2025 — escalating fees and potential account closure above threshold

How to keep your dispute rate low

- Clear billing descriptors: Make sure your company name appears clearly on bank statements — unclear descriptors are the #1 cause of 'I don't recognise this charge' disputes.

- Send receipts immediately after every charge with a clear description of what was charged and how to contact you.
- Make refunds easy: A user who gets a quick refund does not become a chargeback. A user who cannot find your support contact does.
- Send trial reminder emails (Section 5) — directly prevents the 'I forgot I was subscribed' dispute, which is the most common type.

⚠ IF YOU SKIP THIS

- Stripe charges a flat \$15 fee per dispute, win or lose. PayPal charges \$20.
- If your dispute rate exceeds Stripe's threshold, they can place a rolling reserve — holding a percentage of every transaction for 90+ days.
- A frozen payment account while your app is live means users are getting charged but you cannot access the money.

8. International Billing Compliance

Rules apply based on where your users are — not where you are registered.

Region-by-region breakdown

Region / Rule	What's required
EU VAT	Register for VAT and apply the correct rate per EU country. Merchant of Record (MoR) handles this automatically.
India GST	18% GST on digital services for Indian users. Stripe India and Razorpay handle this natively.
India DPDP Act (2025)	User consent for data processing, data localisation for sensitive categories, Data Protection Officer for larger apps.
Canada CASL	Explicit email opt-in required, clear sender identity, and a working unsubscribe in every email. Stricter than CAN-SPAM.
EU SCA	Strong Customer Authentication required for EU payments above certain thresholds. Stripe handles this automatically.
UK Consumer Contracts	Users get 14 days to cancel a digital purchase if it has not been used.

Simplest solution for international billing

Merchant of Record (MoR) — Recommended for Solo Founders

- Use Paddle, Lemon Squeezy, or Dodo Payments as your MoR.
- An MoR acts as the seller of record in every jurisdiction — handling VAT, GST, sales tax, SCA, and refund compliance on your behalf.
- You pay a slightly higher processing fee (~5%) but eliminate the legal complexity of selling globally.
- This is the recommended approach for solo founders and indie teams who don't want a tax accountant in every country.

9. COPPA — If Minors Can Access Your App

US federal law. If any user under 13 can access your app, parental consent is mandatory.

What the law says

- COPPA (US): If any user under 13 can access your app, verifiable parental consent is required before collecting any data from them.
- Must be disclosed in your privacy policy — no exceptions.
- No age gate on your sign-up screen does not protect you. If minors can reasonably access the app, COPPA applies.
- FTC penalties: up to \$51,744 per child per violation.

What to actually do

- Add an age verification screen at sign-up if your app could be accessed by minors.
- If your app is explicitly for under-13s: do not collect personal data without verifiable parental consent — consult a lawyer.
- If your app is for adults only: state this clearly in your App Store listing, your sign-up flow, and your privacy policy.

IF YOU SKIP THIS

- FTC fines: up to \$51,744 per child per violation.
- App Store and Play Store can remove apps that violate COPPA without warning.
- Several apps have been hit with multi-million dollar COPPA settlements — this is actively enforced.

10. Accessibility Compliance

Lower priority for most indie founders — but a real legal risk, especially in the US and EU.

What the law says

- ADA (US): Apps are considered places of public accommodation in many court rulings. Discrimination lawsuits against apps are increasingly common.
- EN 301 549 (EU): European accessibility standard for digital products — applies to apps in the EU market.
- Apple and Google both have accessibility guidelines in their developer documentation — repeated violations can affect app review.

What to actually do

- Ensure sufficient colour contrast ratios (minimum 4.5:1 for body text) — use a contrast checker tool.
- Make all interactive elements reachable via screen readers (VoiceOver on iOS, TalkBack on Android).
- Minimum tap target size: 44x44 points on iOS, 48x48 dp on Android.
- Add alt text for all images that convey information.
- Run a basic accessibility audit with Xcode's Accessibility Inspector or Android Studio's Accessibility Scanner before launch.

Priority Note

- Accessibility is a lower-priority item for most solo founders at launch.
- Focus on Sections 1–7 first. Come back to accessibility for your first major update.
- The legal risk is real but typically arises at scale — not at launch with a few hundred users.

Pre-Launch Checklist

Run through this before you submit to the App Store or go live with billing.

Billing & Subscription

- ☐ Paywall shows: price, billing frequency, trial length, and how to cancel — above the buy button
- ☐ Trial reminder emails are set up and tested — fires 3 days before trial end
- ☐ Annual subscription renewal reminder is set up
- ☐ Cancel subscription button is visible in app settings — tested and working

- ❑ Billing descriptor on bank statements shows your app/company name clearly
- ❑ Receipt email goes out immediately after every charge with support contact
- ❑ Using Apple IAP / Google Play Billing for in-app subscriptions (not an embedded third-party form)
- ❑ Applied for Apple Small Business Program if revenue is under \$1M/year

Privacy & Data

- ❑ Privacy policy is live, linked in app and App Store listing
- ❑ Tracking consent (ATT prompt / cookie consent) is implemented before any SDK fires
- ❑ Age gate or COPPA disclosure if any minor could access the app
- ❑ India DPDP consent flow implemented if targeting Indian users

International

- ❑ If selling to EU users: VAT/tax compliance is handled (MoR or registered)
- ❑ If collecting emails: CASL-compliant opt-in flow for Canadian users
- ❑ Strong Customer Authentication (SCA) handled for EU payments (Stripe handles automatically)

Technical & UX

- ❑ Basic accessibility check done (contrast, tap targets, screen reader labels)
- ❑ Tested the full cancellation flow end-to-end
- ❑ Receipt validation implemented against Apple/Google servers to prevent fraud
- ❑ Support contact visible in app and receipts — users can reach you before filing a dispute

For informational purposes only — not legal advice. Consult a qualified attorney for high-stakes situations.